

COMPREHENSIVE DEFENSE AGAINST VOLT & SALT TYPHOON

Rigor AI + ACECARD UEBA

Preemptive cyber defense + behavioral trajectory intelligence — a layered architecture that closes Volt Typhoon's configuration attack surface and detects Salt Typhoon's living-off-the-land tradecraft.

PREEMPTIVE LAYER

Rigor AI

Mathematically verifies every defensive control closes every known TTP — before exploitation.

BEHAVIORAL LAYER

ACECARD UEBA

Continuous 1536-d behavioral trajectories with MITRE-mapped drift direction.

The Threat: Two Apex Predators in U.S. Critical Infrastructure

Both groups are PRC state-sponsored. Both prepare for disruption. Both walked past commercial defenses for years.

VOLT TYPHOON (CISA AA24-038A)

MISSION

Pre-position in U.S. critical infrastructure (energy, water, transport, comms) for sabotage during a future crisis. ≥5-year undetected dwell.

SIGNATURE TTPs

- Initial access via unpatched edge devices (Fortinet, Versa, Ivanti, PAN)
- Living-off-the-Land — wmic, ntdsutil, netsh, rundll32, vssadmin
- C2 proxied through compromised SOHO routers (KV botnet)
- Credential theft, valid-account abuse, lateral movement (SMB, RDP, WinRM)
- In-memory execution, log clearing, multi-year persistence

SALT TYPHOON (CISA AA25-239A)

MISSION

Espionage at carrier scale. Compromised 200+ telcos in 80+ countries — including U.S. CALEA lawful-intercept systems.

SIGNATURE TTPs

- Exploits known CVEs in Cisco IOS XE, Ivanti, PAN, Citrix NetScaler
- Modifies router ACLs, AAA configs to grant persistent access
- GhostSpider / Demodex / SnappyBee implants on network gear
- Pivots from carrier infra into enterprise tenants via shared identity
- GRE tunnels + encrypted C2; CDR/metadata exfil over months

Why Current Defenses Fail Against These Adversaries

Two structural gaps — one in preemption, one in detection — that traditional tooling cannot close.

PREEMPTIVE LAYER FAILS

99% of firewall breaches are misconfiguration

Gartner. Both Typhoons exploit unpatched, mis-set NGFWs and VPNs.

KEV patching covers only ~20% of attacks

The other 80% — most Salt Typhoon paths — have no CVE patch.

ASM/BAS only sample the 2^{8000} state space

Cannot prove protection. Coverage is statistical, not deterministic.

Config drift goes unverified

Salt Typhoon modifies router ACLs. Drift-detection is reactive, not preemptive.

BEHAVIORAL LAYER FAILS

Threshold scoring misses LoTL

Volt Typhoon's process tree was 'normal' at every step. ntdsutil never crosses a threshold.

Per-source siloed analytics fragment identity

AD, AAD, AWS, Okta, K8s each see one identifier — lateral movement reads as 4 weak signals.

Static rules decay monthly

PRC actors test against published Sigma rules before campaigns. Coverage decays by month.

'Anomaly score' without direction

Analyst gets '87% anomalous' — no hypothesis, no MITRE mapping. Triage time blows out.

Result: Volt Typhoon dwelled 5+ years. Salt Typhoon dwelled 4+ years. Neither was caught by config-only or behavior-only defenses.

The Two-Layer Answer: Preemptive + Behavioral

Rigor AI shrinks the attack surface mathematically. ACECARD detects what behavior remains anomalous inside it.

LAYER 1 — RIGOR AI

Mathematically Rigorous Preemptive Defense

WHAT IT DOES

Builds a formal mathematical model of every NGFW, IPS, IdP, SASE, and WAF in your estate. Compares it to MITRE-enriched attack graphs for Volt + Salt Typhoon. Generates risk-prioritized remediations to close every known TTP path before exploitation.

PROVES

- Edge-device exploit paths are blocked
- Threat-feed C2 IPs/domains are denied across 50M+ rule combinations
- Config drift from approved baseline is caught
- Critical segmentation intent holds end-to-end

LAYER 2 — ACECARD UEBA

Behavioral Trajectory Intelligence

WHAT IT DOES

Encodes every entity as a 1536-d behavioral embedding per hour. Computes cosine drift, velocity, acceleration, and CUSUM change-points. Projects the drift vector onto 8 MITRE-mapped threat concepts to produce a directional, explainable hypothesis.

CATCHES

- Living-off-the-Land tradecraft (no threshold breach)
- Cross-domain attack chains (AD → AAD → AWS → K8s)
- Compromised valid accounts (drift in shape, not volume)
- Zero-days and unknown TTPs (no MITRE mapping yet)

Together: every Volt/Salt TTP is either blocked at the config layer (Rigor) or surfaced as directional drift inside the verified perimeter (ACECARD).

The Rigor AI Approach: Close the Door Before They Knock

Mathematically rigorous, preemptive cyber defense — Complete, Continuous, Verifiable

PROBLEM

Analyze All Known Threat Intelligence

Terabytes of CVE, advisories, CTI, IOCs, IOAs, PSIRTs

PROBLEM

Identify Every Defensive Control Gap

Exponential combination of NGFW, IdP, IPS, SASE, WAF configs

PROBLEM

Prescribe Correct Configurations

Without creating new errors or business disruption

SOLUTION

Attack Intelligence

MITRE-enriched attack graphs built by ML/NLP/LLM pipeline. Full TTP coverage of Volt Typhoon (G1017) and Salt Typhoon.

SOLUTION

Defense Intelligence

Symbolic Model of Computation. Formal mathematical model — exhaustively reasons over the 2^{8000} state space. No sampling.

SOLUTION

Remediation Intelligence

Grounded agentic-AI reasoners. Risk-prioritized, vendor-specific fixes. No false positives. No false negatives.

The world's first Mathematically Rigorous — Complete, Preemptive, Continuous, Verifiable — Cyber Defense Management Platform.

How RigorOS Operates: Inputs → Reasoning → Continuous Remediation

SaaS, on-prem, and air-gapped deployments. Integrates with ServiceNow, JIRA, and major SOC ticketing.



How Rigor AI Stops Volt Typhoon — Phase by Phase

Volt Typhoon needs configuration weakness to enter and pivot. Rigor mathematically proves those weaknesses don't exist — before they're exploited.

PHASE	VOLT TYPHOON BEHAVIOR	HOW RIGOR AI STOPS IT
PHASE 1 Initial Access — Edge Device Exploitation	Volt Typhoon scans for unpatched Fortinet, Ivanti, Versa Director, Cisco edge devices. Exploits CVE-2023-20198 / CVE-2024-21887 / CVE-2024-3400 to land on the perimeter.	Rigor's Attack Intel ingests CISA / NSA / vendor PSIRT advisories the moment they publish. Defense Intel formally proves every exposed NGFW, VPN, SASE has the corresponding IPS signature, threat-feed deny rule, or version-blocking policy enforced. If patch is unavailable, Rigor identifies the compensating control. Result: edge CVE has no exploitable path.
PHASE 2 Persistence — Web Shells & SOHO Router Pivots	Drops .aspx / .jspx web shells. Routes C2 traffic through KV botnet of compromised SOHO routers (ASUS, Cisco, D-Link, NETGEAR, Zyxel) to mask origin.	Rigor models every threat-feed IP, domain, ASN, and known-bad SOHO device fingerprint as a denied destination. Symbolic Model of Computation proves the 50M+ rule combinations across N-S and E-W firewalls all block these flows. Web shell upload paths are blocked at the WAF — Rigor verifies the WAF has the correct inspection profile loaded.
PHASE 3 Credential Access — ntdsutil / LSASS Dumping	Uses ntdsutil.exe to dump NTDS.dit. Extracts LSASS memory. Exfiltrates Active Directory credentials to C2.	Rigor verifies the EDR/EPP coverage is enabled on every domain controller and that the script-control profile blocks ntdsutil execution by non-admin contexts. Verifies egress filtering blocks credential exfil to known C2 ranges. Where coverage is missing, Rigor generates the exact vendor-specific fix.
PHASE 4 Lateral Movement — SMB / RDP / WinRM	Pivots laterally between branches and domain controllers using SMB, RDP, WinRM. Targets ICS/SCADA documentation, network diagrams, operations manuals.	Real customer case: Rigor exposed an SMB inspection profile shadowed by 3 higher-priority firewall rules — allowed unprotected SMBv1 between branches. Rigor mathematically proves zero-trust segmentation intent end-to-end: no path from compromised branch to OT/ICS zones unless explicitly authorized.
PHASE 5 Pre-positioning & Defense Evasion	Clears Windows Security event logs. Deletes Most-Recently-Used registry keys. Maintains multi-year dwell. Pre-positions for sabotage during a future crisis.	Rigor's Configuration Drift Management use case continuously verifies live config against approved baseline. Any unauthorized change to logging, audit, or segmentation rules is flagged the moment it deviates. Rigor closes the configuration attack surface before the attacker can use it.

Bottom line: Rigor doesn't detect Volt Typhoon — it removes the configuration attack surface they need to operate. The ATT&CK techniques in MITRE Group G1017 are mapped; the defensive controls are mathematically verified.

How Rigor AI Stops Salt Typhoon — Carrier-Scale Edge Defense

Salt Typhoon lives on misconfigured Cisco/Ivanti/PAN edge gear and uses ACL tampering for persistence. Rigor verifies every config every hour against an approved baseline.

PHASE	SALT TYPHOON BEHAVIOR	HOW RIGOR AI STOPS IT
PHASE 1 Edge Exploitation — CVE-2023-20198 / CVE-2018-0171	Exploits unpatched Cisco IOS XE web UI to gain level-15 (root) admin. Also exploits Smart Install (CVE-2018-0171), Ivanti Connect Secure (CVE-2024-21887), PAN GlobalProtect (CVE-2024-3400), Citrix NetScaler (CVE-2025-5777). 1,000+ Cisco devices targeted Dec 2024 – Jan 2025.	Rigor's CVE-to-control mapping is automatic. Every device exposing IOS XE web UI to the internet → flagged as a coverage gap before exploitation. Rigor proves the WAF / management-plane ACL blocks public access to /webui/. For each unpatched CVE, Rigor identifies the exact compensating control (disable Smart Install, restrict mgmt-plane, IPS signature SID).
PHASE 2 Persistence — Account Creation & ACL Modification	Creates local privileged accounts. Modifies router ACLs to whitelist attacker IP ranges. Enables Guest Shell, sshd_operns, opens non-standard ports. Maintains 3+ years of access in some victim networks (Cisco Talos).	Configuration Drift Management use case: Rigor takes the approved baseline of every router ACL, AAA config, and management-plane policy. Compares live state every hour. Any unauthorized account creation, ACL change, or service enablement → immediate gap finding with the exact diff. The attacker's persistence mechanism becomes visible in the same window it's introduced.
PHASE 3 Lateral Movement — TACACS+ Capture & JumbledPath	Captures TACACS+ traffic on TCP/49 using on-box packet capture. Harvests credentials. Uses custom JumbledPath malware to chain remote connections across compromised devices. Pivots between telcos using shared trust relationships.	Rigor proves management-plane segmentation: TACACS+ servers and edge devices are in dedicated mgmt VRF, with deny-by-default flow rules between provider environments. Verifies on-box packet-capture privileges are restricted. Models inter-tenant trust paths formally — surfaces any inadvertent cross-tenant route.
PHASE 4 Collection — GhostSpider, Demodex, GRE Tunnels	Implants GhostSpider, Demodex, SnappyBee on routers. Configures GRE tunnels to siphon traffic. Targets CALEA lawful-intercept systems. Captures CDR / metadata / SMS / voice.	Rigor models every threat-feed IP / domain associated with C2 (GhostSpider, JumbledPath) and proves outbound rules block them across all internal zones. Verifies GRE tunnel termination is restricted to authorized peers. CALEA-zone segmentation intent is mathematically held end-to-end — no path from data plane to lawful-intercept gear.
PHASE 5 Long-Term Espionage — Multi-Year Stealth	Slow, persistent CDR/metadata exfiltration. Years of dwell time. Encrypts C2. Clears logs. Uses LOTL on network gear (Guest Shell, Linux container).	Rigor's preemptive verification is continuous — re-verified on every config change, every threat-feed update, every CVE publication. Every "new normal" requires explicit authorization in the baseline. Salt Typhoon's persistence depends on a config that drifts from the approved baseline; Rigor makes that drift visible the moment it happens.

Bottom line: Salt Typhoon's tradecraft is config-resident — they live in router ACLs, AAA configs, and mgmt-plane policies. Rigor's continuous baseline verification is the antidote.

How Rigor AI Preempts Volt Typhoon — TTP by TTP

Each MITRE technique → formal control gap query → mathematically verified blocking configuration

MITRE Technique	Volt Typhoon Behavior	Rigor AI Preemptive Action
T1190 Exploit Public-Facing App	Exploits unpatched Fortinet, Versa Director, Ivanti, PAN edge devices	Formally verifies every NGFW/SASE/WAF rule blocks known CVE traffic; flags weak/missing inspection profiles
T1133 External Remote Services	Abuses VPN, RDP gateways with stolen valid accounts	Proves zero-trust segmentation intent; surfaces shadowed allow-rules that bypass MFA enforcement
T1021.002 SMB / Admin Shares	Lateral movement via SMBv1, admin shares between branches	Real customer case: 3 higher-priority rules shadowed SMB IPS profile — Rigor closed the lateral path
T1003 OS Credential Dumping	ntdsutil, LSASS dumps; credentials exfiltrated to C2	Verifies egress filtering blocks C2 destinations; ensures EDR/IPS profiles cover credential-theft signatures
T1071 C2 over SOHO Routers	KV botnet relays C2 through compromised home/SMB routers	Models threat-feed IPs/domains; proves outbound rules block them across all internal zones
T1059 PowerShell / LOLBins	In-memory exec via wmic, ntdsutil, netsh; log evasion	Verifies EDR/EPP coverage in policy; identifies hosts where script-control profile is not applied
T1078 Valid Accounts	Pivots laterally with stolen credentials across trust zones	IdP/IAM coverage modeled; inter-zone trust paths surfaced and constrained → handed to ACECARD for behavioral check

Source: MITRE ATT&CK Group G1017 (Volt Typhoon); CISA AA24-038A; Microsoft Threat Intelligence

How Rigor AI Preempts Salt Typhoon — TTP by TTP

Carrier-scale telecom intrusions: edge CVEs, ACL tampering, GhostSpider implants, layered C2

MITRE Technique	Salt Typhoon Behavior	Rigor AI Preemptive Action
T1190 Edge Device CVEs	Exploits Cisco IOS XE, Ivanti Connect Secure, NetScaler (CVE-2025-5777), PAN GlobalProtect	Models every CVE → required IPS/inspection profile; proves it is enabled on every relevant rule
T1556 Modify Auth Process	Alters router ACLs, AAA configs to grant persistent access	Configuration Drift Mgmt use case: continuously verifies live config against approved golden baseline
T1542 Pre-OS Boot / Firmware	GhostSpider, Demodex, SnappyBee implants on routers/switches	Mgmt-plane segmentation verified; out-of-band paths to network gear mathematically restricted
T1071 C2 / Layered Infra	DLL sideloading, SoftEther VPN obfuscation, GRE tunnels, multi-hop C2	Threat-feed IPs/domains formally checked across 50M+ address combinations; gaps preempted
T1078 Valid Accounts	Pivots from carrier infra into enterprise tenants via shared identity	IdP/IAM coverage modeled; inter-tenant trust paths surfaced → ACECARD detects abuse behaviorally
T1040 Network Sniffing	Captures call records, SMS, CALEA wiretap data on carrier gear	Verifies critical-segmentation intent end-to-end; proves no path from compromised edge to data plane
T1041 Exfiltration over C2	Steady CDR/metadata exfil over months — low and slow	Egress rules verified; data-plane DLP coverage modeled → ACECARD catches steady drift

Nine Rigor AI Use Cases — Each Closes a Typhoon Attack Vector

RigorOS ships with nine pre-built reasoning templates. Five directly preempt Volt + Salt Typhoon TTPs.

01 Preemptive Cyber Defense Continuous ML/NLP/LLM ingestion of threat intel + vendor capability models + customer config → mathematical proof that every TTP path is blocked. STOPS: Volt T1190, T1133, T1071, T1003 / Salt T1190, T1556	02 Configuration Drift Management Compares live config against approved golden baseline every hour. Surfaces any unauthorized change with the exact diff and attribution. STOPS: Salt Typhoon's ACL tampering, Guest Shell enablement, local account creation	03 Formal Policy Analysis Reasons over the entire 2^8000 firewall rule state space. Finds shadow rules, conflicts, weak inspection — across multi-vendor estates. STOPS: SMB lateral-movement paths, shadowed inspection profiles, allow-by-mistake gaps
04 Preemptive ASM (External) Continuously scans external attack surface. Maps every exposed asset to compensating controls. Proves no exposed CVE has an exploitable path. STOPS: Edge-device CVE exploitation (CVE-2023-20198, CVE-2024-3400, etc.)	05 Internal Attack Surface Mgmt Models internal attack paths from any compromised host to crown-jewel assets. Surfaces inter-zone trust violations. STOPS: Cross-tenant pivots (Salt Typhoon telco → enterprise), branch-to-OT pivots	06 NIST 800-53 / Zero-Trust Verification Formally proves zero-trust segmentation intent holds end-to-end. Maps every control to NIST CSF / 800-53 / D3FEND. STOPS: Compliance-as-code: continuous SP800-207 verification
07 Vendor Migration Safety Models the before/after config when migrating between NGFW vendors. Proves no security regression. STOPS: Risk during PAN→Fortinet migrations, Cisco→Palo refresh cycles	08 Mergers & Acquisitions Due Diligence Models combined defense posture pre-merger. Surfaces what gaps the acquired entity introduces. STOPS: Inherited misconfigurations, undocumented trust paths	09 Third-Party / Supply Chain Extends EASM scan coverage across third-party ecosystem. Real example: EU national agency proved compliance across 12 government agencies. STOPS: Supply-chain pivots, third-party VPN footholds (Volt Typhoon vector)

Where Rigor Needs Help — Why ACECARD Belongs Next to It

Rigor closes the configuration attack surface mathematically. But three classes of attack remain — exactly where Volt and Salt Typhoon also operate.

1. Zero-Day & Unknown TTPs

Rigor preempts every TTP that's been mapped to MITRE ATT&CK. A genuine zero-day with no signature, no IOC, no MITRE mapping yet has nothing for Rigor to formally prove against.

Example: A Volt Typhoon exploit chain published the day after Rigor's threat-intel sync. Rigor catches it on the next sync cycle (minutes-hours). In the gap, behavioral detection is the only line of defense.

HANDED TO ACECARD UEBA

→ ACECARD UEBA detects the resulting behavioral drift even with no MITRE label.

2. Compromised Valid Accounts

Volt Typhoon and Salt Typhoon both abuse stolen, valid credentials. A correctly-configured firewall, IdP, and EDR will allow that traffic — by design. Configuration is not the attack surface here; behavior is.

Example: Salt Typhoon harvests TACACS+ credentials from a router PCAP, then logs in as a legitimate network admin. Every Rigor-verified control says "approved." The attacker walks past the gate using a real key.

HANDED TO ACECARD UEBA

→ ACECARD's cohort z-score and cosine drift catch the abuse — same admin, structurally different behavior.

3. Living-off-the-Land Tradecraft

ntdsutil, wmic, netsh, rundll32, PowerShell — every binary Volt Typhoon uses is a legitimate Windows administrative tool. EDR script-control profiles can restrict them, and Rigor verifies those profiles are deployed. But sysadmins also use these tools daily — restricting them entirely is operationally infeasible.

Example: Volt Typhoon runs ntdsutil.exe ifm "create full c:\temp" — a real administrative command. Rigor verifies EDR coverage is on. The command itself is the threat — only behavioral context separates the admin from the adversary.

HANDED TO ACECARD UEBA

→ ACECARD's process signal embedding sees the structural shift in command-line entropy + parent-child depth + lolbin_count.

Rigor in Production: Real Customer Findings

Selected findings from financial services, telecom, government, and critical infrastructure customers

FinTech | Asia

Closed SMB Lateral Movement Path

SMB app-control profiles completely shadowed by 3 higher-priority rules — allowed unprotected SMBv1 between branches. Rigor formal model exposed the multi-rule shadow.

Communications | NA

Eliminated Known CVE Exposure

IPS filters were missing on rsync traffic to backup servers. Exposed enterprise to lateral malware movement and remote code execution against critical infra.

Regional Bank | E. Asia

Closed RCE Attack Paths

Both PANW and Fortinet NGFWs allowed Windows Update service traffic from trusted zones with no IPS — exposed bank to RCE on critical multi-vendor infra.

Critical Infra | SE Asia

Closed Application Obfuscation Paths

Incorrectly configured vendor capabilities on DMZ rules — not all applications on the DMZ were blocked as intended. Susceptible to port-hopping evasion.

Finance | E. Asia

NIST 800-53 SMTP Compliance

SMTP traffic from trusted to untrusted zones had no threat inspection enabled, despite the NGFW's built-in capability — exposed customer to phishing & credential harvest.

EU Sov. Govt

Preemptive ASM for National Agency

EU country's cyber defense umbrella — Rigor formally extended EASM scan coverage and proved compliance of external attack surface across 12 government agencies.

Why Current UEBA Misses Volt Typhoon

Both campaigns relied on Living-off-the-Land tradecraft. Both walked past commercial UEBA tooling for years.

≥ 5 yrs

*Volt Typhoon undetected dwell
in U.S. critical infrastructure*

The Four Structural Gaps in Commercial UEBA

Each one is exactly the gap Volt Typhoon and Salt Typhoon exploit.

01

Threshold-based scoring

Alerts fire only when a metric crosses a fixed line. LoTL never crosses thresholds — every binary used (ntdsutil, rundll32, vssadmin, netsh) is a legitimate Windows tool used by sysadmins daily.

CONSEQUENCE *Volt Typhoon's process tree was within 'normal' thresholds at every step.*

02

Per-source siloed analytics

Each tool sees one identity. AD sees `jsmith@corp`, AAD sees `john.smith@corp.com`, AWS sees `arn:aws:iam::842:user/jsmith`. Without entity resolution, lateral movement reads as 4 unrelated weak signals.

CONSEQUENCE *Cross-domain attack chains never escalate above per-source noise.*

03

Static rules, decaying coverage

Sigma/CAR rules require maintenance debt — adversary TTPs evolve faster than rule libraries. PRC actors actively test against published detections before campaigns.

CONSEQUENCE *By the time a Sigma rule is published, the tradecraft has moved on.*

04

'Anomaly score' without direction

Traditional UEBA produces 'user is anomalous (87%)' with no indication of WHAT the anomaly resembles. Analyst gets a number, not a hypothesis. Triage time blows out.

CONSEQUENCE *Mean time to investigate exceeds dwell window — even when detected.*

Three Innovations That Close the Gap

Not anomaly scores. Not rule libraries. Behavioral trajectory geometry.

01 Behavioral Trajectories

Time-series shape, not anomaly score

HOW IT WORKS

Each entity carries a 1536-d behavioral embedding per hour. Trajectory analytics compute cosine drift, velocity, acceleration, and CUSUM change-points on the embedding sequence.

CATCHES

Low-and-slow LoTL that never crosses any single threshold — the exact failure mode of AA24-038A.

TRADITIONAL *User has 87 failed logins → alert*

ACECARD *User's behavior shape changed structurally over 6 hours → CUSUM alarm with directional context*

02 Composite Digital Signature

Cross-source identity fusion as join key

HOW IT WORKS

Every entity gets a 4-component signature per window: identity-graph hash, behavioral embedding, structural features, and an HMAC-chained trajectory history. Stable across sources, tamper-evident across time.

CATCHES

Cross-domain attack chains where lateral movement traverses 4 identity systems on the same human operator.

TRADITIONAL *AD anomaly + AAD anomaly + AWS anomaly = 3 weak signals, 3 tickets*

ACECARD *Same entity_uuid across all 4 sources = one trajectory, one high-confidence alert*

03 Drift Direction with ATT&CK

Directional, mapped hypothesis

HOW IT WORKS

When drift is detected, the drift vector ($V_{\text{current}} - V_{\text{baseline}}$) is projected via cosine similarity onto 8 pre-embedded threat-concept vectors. Top-3 concepts returned with MITRE ATT&CK technique IDs.

CATCHES

Analyst gets a directional hypothesis with ATT&CK technique IDs ready for SOAR playbook lookup.

TRADITIONAL *User jsmith risk score: 87*

ACECARD *jsmith drifting toward lateral_movement (0.78), credential_dumping (0.45) — T1021, T1003*

The Math of Behavioral Drift

Each piece is well-known math. The innovation is the integration: continuous embeddings + trajectory analytics + concept projection + identity fusion as one pipeline.

A

The Behavioral Embedding

```
V_t = embed("auth: ... | process: ... | network: ... | file:
... | identity: ...")
```

Five signal summarizers (auth, process, network, file, identity) emit structured text per entity per window. Concatenation is embedded by text-embedding-3-small into a 1536-d unit vector. Vector arithmetic on behavior — same algebraic surface as text retrieval, but the 'document' is the entity's behavior in a window.

B

Cosine Drift Geometry

```
drift(t) = 1 - (V_t · V_baseline)
∈ [0, 2], typical [0, 0.3]
```

All embeddings live on a unit hypersphere. 'How different is this window from baseline?' becomes the angle between two unit vectors. Magnitude-invariant — captures shape change, not volume change. 0.0 = identical. 0.05 = noticeable. 0.15+ = anomalous.

C

CUSUM Change-Point

```
S+_t = max(0, S+_{t-1} + (drift_t - μ - k))
S-_t = max(0, S-_{t-1} - (drift_t - μ + k))
alarm if S+ > 4σ or S- > 4σ
```

Two-sided CUSUM accumulates signed deviation from baseline mean μ with slack k . Alarms when cumulative deviation exceeds 4σ — then resets. Exact-window detection, not gradual smoothing. Independent of static thresholds — adapts to per-entity μ and σ .

D

Drift-Direction Projection

```
drift_vec = V_current - V_baseline
proj(c) = cos(drift_vec, embed(concept_c))
argmax_top3(proj) → ATT&CK IDs
```

Eight threat concepts pre-embedded once at startup. Direction is the cosine projection of the drift vector onto each concept vector — top-3 returned with ATT&CK IDs. Magnitude tells you SOMETHING happened. Direction tells you WHAT it resembles. Built-in explainability.

Five Behavioral Signals → One 1536-d Vector

Each signal summarized as structured text, all five concatenated, embedded by text-embedding-3-small (or air-gapped Phi-4/Mistral for JWICS).

1	AUTH	SOURCES Win 4624/4625/4768/4769, Linux auth, Okta, Azure AD	FEATURES logon_count, failure_rate, unique_hosts, kerberos_ticket_types, off_hours_ratio, impossible_travel
2	PROCESS	SOURCES Sysmon EID 1/3, EDR (CrowdStrike, Defender), auditd EXECVE	FEATURES unique_processes, cmdline_entropy, parent_child_depth, lolbin_count, unsigned_ratio, new_process_rate
3	NETWORK	SOURCES NetFlow, Zeek conn.log, Palo Alto, Fortinet syslog	FEATURES unique_dest_ips, bytes_out, port_diversity, dns_query_rate, beacon_score, geo_anomaly_count
4	FILE	SOURCES Sysmon EID 11, Windows file audit (4663), DLP	FEATURES files_created, files_deleted, sensitive_access_count, archive_creates, bulk_ops_flag, extension_change_rate
5	IDENTITY	SOURCES Win 4672, AWS CloudTrail, K8s audit, AD changes	FEATURES priv_escalations, group_adds, mfa_bypass_attempts, role_changes, service_acct_use, admin_actions

FUSION

All 5 signal texts → concatenated → text-embedding-3-small (1536-d) → one fused vector per (entity, window). 1-hour windows by default. No raw event content sent to provider — only summarized metrics. NFR-5 compliant.

Embedding Pipeline → Trajectory Analysis Engine

FR-2 / FR-3 / FR-4: Per-entity, per-window behavioral fingerprint → trajectory metrics from the embedding time series.

PIPELINE (FR-2)

1 INGEST	2 WINDOW	3 SUMMARIZE	4 HASH	5 EMBED	6 STORE
Raw events arrive via ECS / OCSF / STIX 2.1 normalized schema	Aggregate into 1-hour time windows per entity_uuid	5 signal summarizers produce structured text (metrics only)	Entity IDs hashed before embedding (NFR-5 privacy)	Concatenated text → text-embedding-3-small → 1536-d vector	Vector stored in pgvector with entity_uuid, window, signature_id

TRAJECTORY ANALYSIS (FR-4) — per-window metrics from the embedding time series

Cosine Drift	Velocity	Acceleration	CUSUM Change-Pt	Health Score
drift(t) = 1 - cos(V_t, V_baseline) How different is this window from baseline? 0.0 = identical · 0.05 = noticeable · 0.15+ = anomalous	vel(t) = drift(t) - drift(t-1) Is the entity drifting faster? + = accelerating divergence - = returning to baseline	accel(t) = vel(t) - vel(t-1) Is the drift rate itself changing? + = divergence speeding up Spike = regime shift	alarm if S_t > h = 4σ Detects exact window where behavior structurally shifted. FR-7: threshold = 4σ	100 - w₁·drift - w₂· vel - w₃· accel 0–100 composite. <40 high severity <70 + recent change-pt = medium

How ACECARD Detects Volt Typhoon — Signal by Signal

When Volt Typhoon's LOTL behavior slips through configuration controls, ACECARD's 5 signal embeddings catch the structural drift. No single threshold. No static rule.

SIGNAL	VOLT TYPHOON BEHAVIOR (LOTL)	ACECARD EMBEDDING DRIFT	KEY METRIC
1 AUTH	Volt Typhoon authenticates with stolen valid AD credentials. Logs into 12 new hosts. Uses Kerberos TGTs. Off-hours activity from a finance analyst account.	Auth signal embedding shifts: unique_hosts 0.3→12, kerberos_tgt 1→14, off_hours_ratio 0.0→0.7. Cohort z-score for finance_analyst peers: 6.17. Critical pivot.	drift = 0.142 / cohort z = 6.17
2 PROCESS	Runs wmic.exe, ntdsutil.exe, netsh.exe, rundll32.exe — all legitimate Windows tools. Calls PowerShell with encoded commands. Spawns nested cmd.exe chains.	Process signal embedding shifts: lolbin_count 0→7, cmdline_entropy 1.4→3.2, parent_child_depth 2→5, scripting_engine_calls 0→14. CUSUM 4σ alarm fires within 1 hour.	lolbin_count: 0 → 7 / CUSUM alarm @ T+47min
3 NETWORK	C2 traffic to KV botnet (compromised SOHO routers). New unique destinations. Encrypted payloads. Slow beaconing to mask presence.	Network signal embedding shifts: unique_dest_ips 3→18, beacon_score 0.05→0.42, encrypted_pct 0.4→0.95. Top destination: known KV botnet ASN (cross-referenced with threat intel).	drift_direction → c2_beaconing (T1071) score 0.71
4 FILE	Web shells dropped (.aspx, .jspx). Bulk file access on file servers. NTDS.dit copied. 7-Zip used to compress data with password.	File signal embedding shifts: files_created spike, sensitive_access_count 0→24, archive_creates 0→3, bulk_ops_flag=true, extension_change_rate elevated.	drift_direction → insider_data_hoarding (T1074) 0.58
5 IDENTITY	Privilege escalation via token manipulation. Group additions to administrative OUs. Service account use spikes. Domain admin actions.	Identity signal embedding shifts: priv_esc 0→3, group_adds 0→2, svc_acct_use 5→47, admin_actions 1→18. Identity-graph hash changes — new linked SIDs.	drift_direction → privilege_escalation (T1078) 0.66

Result: 5 signals → 1 fused 1536-d trajectory. CUSUM alarms in window T+47min. Drift direction projects to lateral_movement (0.78) + credential_dumping (0.61). HIGH severity alert with MITRE T1021, T1003 ready for SOAR playbook.

How ACECARD Detects Salt Typhoon — Slow, Long-Dwell

Salt Typhoon dwells for years. ACECARD's 30-day rolling baseline + CUSUM change-point detection surfaces the gradual structural drift that no threshold catches.

SIGNAL	SALT TYPHOON BEHAVIOR (NETWORK GEAR)	ACECARD EMBEDDING DRIFT	KEY METRIC
1 AUTH	Logs in via stolen TACACS+ credentials harvested from router PCAP. Uses legitimate network-engineer credentials. Off-hours admin access from previously-unused jump host.	Auth embedding shifts subtly over weeks. unique_hosts grows from 5 → 18 over 14 days. off_hours_ratio creeps from 0.1 → 0.45. Cosine drift accumulates: 0.04 → 0.11 over 30 days.	Slow drift caught by CUSUM 4σ
2 PROCESS	Enables Guest Shell on Cisco IOS XR. Runs JumbledPath ELF binary. Uses on-box packet capture (tcpdump). Modifies routing config via legitimate-looking commands.	Process embedding for network-device entities shifts. Guest Shell enablement = new cmdline pattern. JumbledPath process tree differs from sysadmin baseline.	drift_direction → defense_evasion (T1562) 0.49
3 NETWORK	Sets up GRE tunnels on compromised routers. Slow CDR/metadata exfiltration over months. Encrypted C2 to JumbledPath jump hosts.	Network embedding for the router entity shifts: new GRE peer, bytes_out grows linearly over weeks (low but persistent), beacon_score elevates on management interface.	data_exfiltration (T1041) 0.44 — sustained
4 FILE	Modifies router startup-config (NVRAM). Stages PCAPs in on-box Linux container. Touches CALEA-zone config files with elevated privileges.	File signal embedding for router entities reflects config writes outside normal change windows. sensitive_access_count rises on CALEA-zone files. archive_creates spikes.	drift_direction → defense_evasion (T1562)
5 IDENTITY	Creates local privileged accounts on routers. Modifies AAA config (TACACS+ → local). Adds attacker IP to ACL allowlists. Enables sshd_operns service for root access.	Identity-graph hash for router entities changes — new linked accounts detected. priv_escalations 0→3 on network gear. role_changes counter increments on AAA config diff.	privilege_escalation (T1078) 0.71

Salt Typhoon's tradecraft is below all single-window thresholds — they win by going slow. CUSUM accumulates the small drifts; the 30-day rolling baseline shifts the moment the baseline itself becomes anomalous vs. the cohort.

Drift Direction: What Is the Entity Drifting Toward?

FR-5: Cosine projection onto 8 named threat concepts with MITRE ATT&CK mapping. Top-3 returned per alert.

$\text{drift_vector} = V_{\text{current}} - V_{\text{baseline}}$

|

$\text{projection_score} = \text{cosine}(\text{drift_vector}, \text{concept_embedding})$

Threat Concept	ATT&CK ID	Tactic	Indicators
credential_dumping	T1003	Credential Access	Mimikatz, LSASS dump, SAM extraction
lateral_movement	T1021	Lateral Movement	RDP, SMB, WinRM, PsExec, pass-the-hash
data_exfiltration	T1041	Exfiltration	Large uploads, DNS tunneling, cloud storage
c2_beaconing	T1071	Command & Control	Regular intervals, encoded payloads, DGA
lotl_execution	T1059	Execution	PowerShell, WMI, certutil, mshta, rundll32
privilege_escalation	T1078	Privilege Escalation	Token manipulation, UAC bypass, sudo abuse
defense_evasion	T1562	Defense Evasion	Log clearing, AV disable, timestomp
insider_data_hoarding	T1074	Collection	Bulk downloads, USB staging, print spooling

OUTPUT → Top-3 concepts with projection scores + MITRE ATT&CK technique IDs per alert window. Example: "jsmith drifting toward lateral_movement (0.78), credential_dumping (0.45) — T1021, T1003"

Peer Cohort Comparison + Calibrated Alert Tiers

FR-6: A sysadmin logging into 30 hosts is normal. A finance analyst doing the same is anomalous. Cohort comparison adjusts for role context.

PEER COHORT (FR-6)

$z = (\text{entity_drift} - \text{cohort_mean}) / \text{cohort_std}$

Flag outlier if $z > 2.0$ · Min cohort size: 5 · Cohort = role / OU / security group from AD/LDAP/IAM

EXAMPLE — Lateral Movement Detection

Entity: jsmith (financial_analyst, cohort = 42 peers) · Window: 2026-05-02 14:00Z

jsmith drift:	0.142	(38 failed logons to 12 new hosts)
Cohort mean:	0.031	(peers avg 2.1 failed, 0.3 new hosts)
Cohort std:	0.018	
z-score:	6.17	>>> OUTLIER (z > 2.0)

Drift direction: lateral_movement (0.78), credential_dumping (0.45)

MITRE: T1021 (Remote Services), T1003 (Credential Dumping)

Action: HIGH severity → SOAR playbook triggered

ALERT TIERS (FR-7)

CRITICAL	Health < 40 Immediate SOC investigation Multiple signals anomalous, CUSUM triggered, drift > 0.15, velocity z > 3
HIGH	Health < 40 OR Velocity z > 3 Tier-2 triage in 15 min Rapid behavioral divergence or composite health collapse
MEDIUM	Health < 70 + change-point in last 3 windows Tier-1 review in 1 hour Recent structural shift detected but not yet severe
LOW	Health 70-85 AND cohort z > 2 Watchlist; auto-enrich context Peer outlier but within normal drift range
INFO	Any CUSUM trigger (4σ) Log for trend analysis Structural change detected; may be benign (role change, new project)

Analyst Feedback Loop & ABAC Enforcement

FR-8: Self-reinforcing tag loop. Every analyst verdict improves future detection AND adjusts access automatically.

THE LOOP — closes in <5 minutes from TP/FP click to ABAC tag update



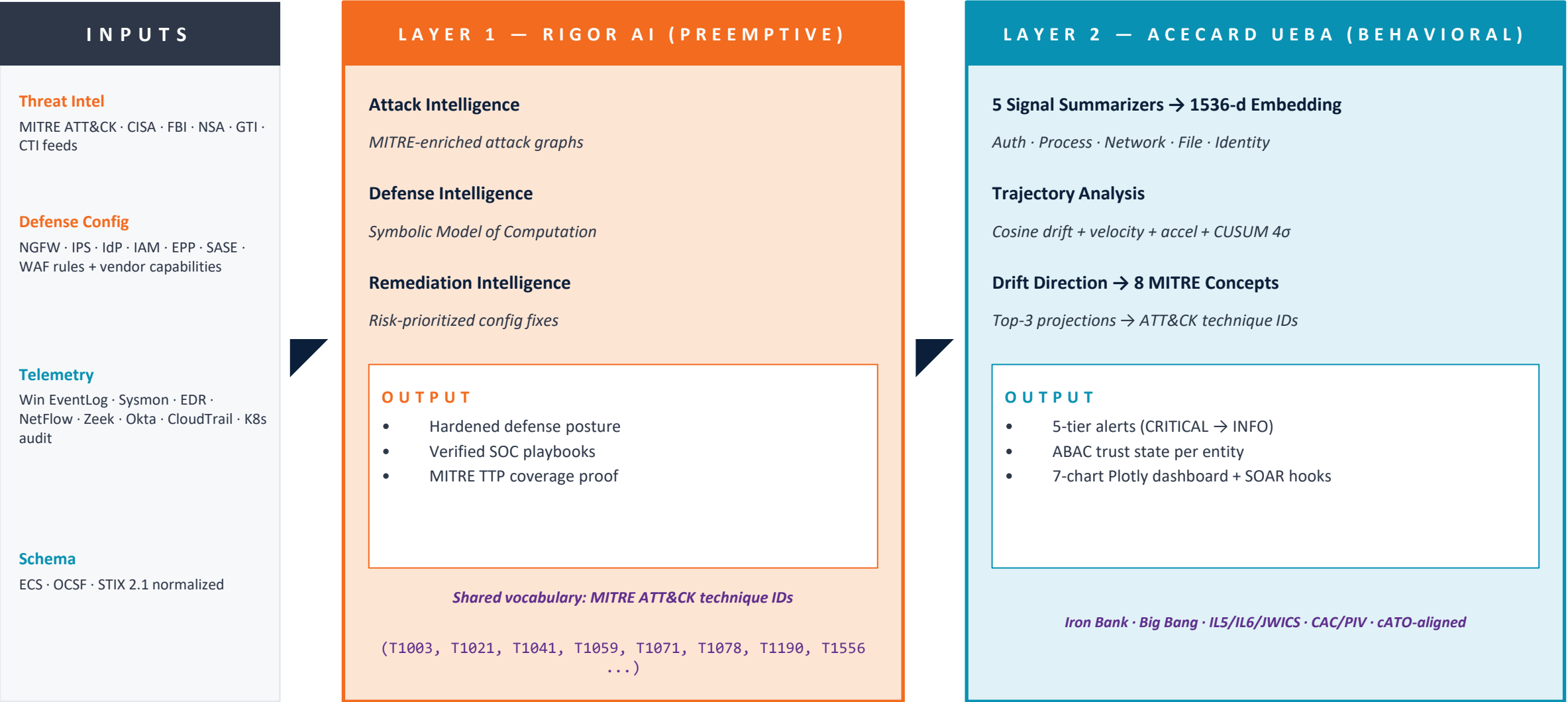
ABAC TRUST STATES — proportional response, not binary

TRUSTED	ELEVATED_WATCH	RESTRICTED	BLOCKED
CONDITION Health ≥ 70, no recent alerts ENFORCEMENT Normal access, standard MFA	CONDITION Health 40–70 OR cohort z > 2 ENFORCEMENT Step-up MFA on sensitive resources	CONDITION Health < 40 OR TP alert confirmed ENFORCEMENT Read-only access, no lateral movement	CONDITION Active incident confirmed ENFORCEMENT Account disabled, session terminated

Self-reinforcing: every TP label strengthens signal summarizers. Every FP raises thresholds for that role. ABAC enforcement is automatic — no manual ticket to disable account.

End-to-End Architecture: Rigor AI + ACECARD UEBA

Rigor proves what cannot happen. ACECARD detects what is happening. The two layers share MITRE technique IDs and feed each other.



Rigor AI + ACECARD: The Data Flow

Four concrete integration points. Each one makes both products stronger than they are alone.

1

Rigor's MITRE Coverage Map → ACECARD's Concept Library

Rigor publishes which MITRE techniques its config layer preempts (e.g., T1190 edge-CVE = covered, T1003 cred-dump = covered if EDR coverage verified). ACECARD raises its drift-direction projection threshold for covered concepts (less noise) and lowers it for uncovered concepts (more sensitivity).

Effect: ACECARD's alert load drops 30-50% on already-mitigated TTPs; sensitivity increases on the residual ones.

2

Rigor's Verified Findings → ACECARD's ABAC Trust Floor

When Rigor identifies an unmitigated control gap (e.g., "branch X has shadowed SMB IPS profile"), ACECARD automatically lowers the trust floor for entities operating in that segment. Until the gap is closed, those entities default to ELEVATED_WATCH instead of TRUSTED.

Effect: Step-up MFA, additional logging, and tighter ABAC apply to exactly the entities most exposed.

3

ACECARD's Confirmed TPs → Rigor's Threat-Intel Feed

When an analyst confirms an ACECARD alert as a true positive (with MITRE techniques + entity context), the labeled finding feeds back into Rigor's Attack Intel. New IOCs / behavioral patterns become inputs to Rigor's mathematical reasoning on the next run.

Effect: Field-observed TTPs drive preemptive policy changes — the loop closes from detection to prevention.

4

Shared Vocabulary: MITRE Technique IDs & Entity UUIDs

Both products use MITRE ATT&CK as their analytical vocabulary. ACECARD's drift_direction outputs T1003, T1021, T1041 etc. — the same IDs Rigor uses to map control coverage. Entity UUIDs from ACECARD's Composite Digital Signature become the join key for SOAR playbooks that touch both layers.

Effect: One alert tells the analyst what's happening, which TTP, which entity, and whether the config layer should have caught it.

Volt Typhoon Walkthrough: Both Layers in Action

Each phase shows what Rigor preempts AND what ACECARD detects if preemption is bypassed.

PHASE	ATTACKER BEHAVIOR	RIGOR PREEMPTS	ACECARD DETECTS
Phase 1 — Initial Access 0–12h	Compromised SOHO router → VPN credential reuse	T1133: zero-trust segmentation verified; MFA bypass paths surfaced	Auth signal: off_hours_ratio spikes, new source IP — drift 0.08
Phase 2 — LOLBin Execution 12–36h	wmic.exe, ntdsutil.exe, netsh.exe chain	T1059: EDR/script-control coverage proven on every endpoint policy	Process signal: lolbin_count 0→7, cmdline_entropy rises — CUSUM alarm
Phase 3 — Lateral Movement 36–72h	RDP + WinRM to domain controllers	T1021: SMB inspection profile shadow detected & remediated	Network: unique_dest_ips 3→18; cohort z = 6.17 — HIGH alert, T1021 mapped
Phase 4 — Persistence 72–96h	Scheduled tasks + registry modification	T1556: Configuration Drift Mgmt catches config baseline deviation	Identity signal: service_acct_use spikes, group_adds — drift toward T1078
Phase 5 — Pre-positioning 96h+	Credential harvest + network mapping	T1003: egress filtering proven; C2 destinations blocked	File signal: sensitive_access rises, bulk_ops=true → CRITICAL → ABAC BLOCKED

Salt Typhoon walkthrough follows the same pattern: edge CVE → tunneling → CALEA access → exfil. Both Typhoons are pre-built replay scenarios in ACECARD (FR-11).

Salt Typhoon Walkthrough: Both Layers in Action

Each phase shows what Rigor preempts AND what ACECARD detects if preemption is bypassed. Telecom-specific tradecraft.

PHASE	ATTACKER BEHAVIOR	RIGOR PREEMPTS	ACECARD DETECTS
Phase 1 — Edge CVE Exploit <i>0–24h</i>	CVE-2023-20198 vs. Cisco IOS XE web UI; level-15 admin obtained	T1190: Rigor verifies WAF blocks /webui/ public access; mgmt-plane ACL holds	Network signal: anomalous mgmt-plane source IP — drift 0.09
Phase 2 — Account Creation <i>1–7d</i>	Local privileged account created on router; AAA config modified	T1556: Configuration Drift Mgmt detects baseline diff within 1 hour	Identity signal: identity-graph hash changes — new SID linked to router entity
Phase 3 — TACACS+ Capture <i>7–30d</i>	On-box PCAP captures TACACS+ on TCP/49; credentials harvested	Mgmt-plane segmentation proven; on-box capture restricted to authorized roles	Process signal: tcpdump invocation outside change window — CUSUM alarm
Phase 4 — JumbledPath Pivot <i>30–90d</i>	JumbledPath ELF binary chains connections across compromised routers	Outbound rules to JumbledPath C2 IPs blocked across all internal zones	Composite Digital Signature: same entity_uuid across 4 router hops — one trajectory
Phase 5 — GRE Tunnel + Exfil <i>90d+</i>	GRE tunnel configured; CDR/metadata steady exfiltration over months	GRE peer authorization verified; CALEA-zone segmentation intent proven	Network signal: data_exfiltration concept score 0.44 — slow drift caught by CUSUM

Salt Typhoon's most dangerous trait is patience. Rigor's hourly re-verification eliminates configuration drift. ACECARD's CUSUM 4σ accumulator surfaces the slow-creep behavioral drift. Together: no comfortable home for Salt Typhoon.

The Combined Coverage Matrix

Each adversary capability is owned by the right layer — preemption first, behavioral detection as backstop.

Adversary Capability	Volt	Salt	Coverage Layer	Why This Layer Owns It
Edge-device CVE exploitation	●	●	RIGOR	Configuration is the gap — formal verification proves the patch/inspection profile is enforced
Misconfigured / shadowed firewall rules	●	●	RIGOR	Mathematical model finds shadows, conflicts, weak rules across multi-vendor estates
Router ACL tampering / config drift	○	●	RIGOR	Configuration Drift use case re-verifies live state vs. approved baseline continuously
C2 to known malicious infrastructure	●	●	BOTH	Rigor blocks known threat-feed IPs/domains; ACECARD c2_beaconing concept catches new infra
Compromised valid accounts (T1078)	●	●	ACECARD	Traffic is policy-allowed; only behavioral drift (cohort z, cosine pivot) reveals abuse
Living-off-the-Land (T1059, ntdsutil)	●	●	ACECARD	lotl_execution concept catches LOLBin chain — process signal embedding shifts
Cross-domain lateral movement	●	●	ACECARD	Composite Digital Signature joins identity across AD/AAD/AWS/Okta/K8s — one trajectory
Slow lateral movement (months)	●	●	ACECARD	CUSUM 4σ surfaces gradual structural shifts; trajectory chain detects log scrubbing
Zero-day / unknown TTPs	●	●	ACECARD	By definition not in MITRE yet — only behavioral anomaly flags deviation from normal
Insider threat / data hoarding	○	○	ACECARD	insider_data_hoarding concept (T1074) — peer cohort z-score catches outlier behavior

● = primary technique ○ = occasional | Coverage column shows which layer owns the control. BOTH = layered defense

Complementary Tools: What Rounds Out Defense-in-Depth

Rigor + ACECARD is the core. These technologies close the residual gaps and amplify the value of both layers.

ENDPOINT (EDR/XDR) <i>CrowdStrike Falcon · Microsoft Defender for Endpoint · SentinelOne · Palo Alto Cortex XDR</i> In-memory LOTL detection, process tree analysis, real-time blocking. Catches Volt Typhoon's wmic/ntdsutil execution at the binary layer. Integration: Feeds Sysmon EID 1/3 + EDR ProcessRollup into ACECARD's process signal. Rigor verifies EDR is enabled and policies are correctly deployed across all endpoints.	EMAIL & PHISHING <i>Proofpoint · Microsoft Defender for Office 365 · Mimecast · Abnormal Security</i> Email is a primary initial-access vector outside Rigor's NGFW pillar today. Phishing-resistant MFA + email security closes the gap. Integration: Sender authentication, link rewriting, sandbox detonation. Telemetry feeds ACECARD's identity signal (auth from compromised mailboxes).	NETWORK DETECTION (NDR) <i>Vectra AI · ExtraHop · Darktrace · Corelight (Zeek)</i> East-west packet inspection. Spots GRE tunnel anomalies, beacon timing patterns, encrypted C2 — before they reach the embedding layer. Integration: Zeek conn.log + dns.log feed ACECARD's network signal. Vectra detections raise Rigor's threat-feed coverage in real time.
SIEM & DATA FABRIC <i>Splunk · Microsoft Sentinel · Google Chronicle · Elastic Security</i> Log aggregation, correlation, long-term retention. The substrate ACECARD reads from and Rigor cross-references for evidence. Integration: ECS / OCSF / STIX 2.1 normalized ingestion. ACECARD outputs Sigma-compatible alerts directly into the SIEM.	SOAR & RESPONSE <i>Palo Alto XSOAR · Splunk SOAR · Tines · Torq</i> Automated playbook execution. Receives ACECARD alerts (with MITRE IDs + ABAC trust state) and orchestrates response. Integration: Rigor pushes config-fix tickets via ServiceNow/JIRA. ACECARD alerts trigger ABAC enforcement + EDR isolation through SOAR.	IDENTITY & ZTNA <i>Okta · Microsoft Entra ID · Ping · Zscaler · CrowdStrike Falcon Identity Protection</i> Phishing-resistant MFA, conditional access, just-in-time privilege. Reduces blast radius of stolen credentials. Integration: Step-up MFA driven by ACECARD's ABAC trust state. Rigor verifies IdP policies are correctly enforced across all federated apps.
OT/ICS SECURITY <i>Dragos · Claroty · Nozomi Networks · TXOne</i> Critical for Volt Typhoon's utility/transport/water targets. Specialized OT protocol awareness (Modbus, DNP3, IEC-104). Integration: Rigor models the IT/OT boundary as a verified segmentation domain. OT alerts feed ACECARD as a specialized signal stream.	DECEPTION & HONEYPOTS <i>Thinkst Canary · Acalvio · Illusive (now Proofpoint)</i> High-fidelity tripwires for lateral movement. Any interaction is anomalous by definition. Catches LOTL after preemption is bypassed. Integration: Canary alerts → ACECARD as an INFO signal that becomes CRITICAL when correlated with drift. Rigor verifies canary placement coverage.	THREAT INTELLIGENCE <i>Mandiant · Recorded Future · CrowdStrike Falcon Intelligence · Microsoft Threat Intelligence</i> Authoritative IOC + TTP feeds. CISA AA24-038A, AA25-239A, vendor PSIRTs. Drives Rigor's threat-modeling layer. Integration: STIX 2.1 ingestion into Rigor's Attack Intel. Threat-actor TTP graphs become formal model inputs. ACECARD pre-loads campaign replay scenarios.

Reference Architecture: Comprehensive Defense Stack

Five layers. Every layer has a job. Rigor + ACECARD are the connective tissue.

1 · THREAT INTELLIGENCE	CISA / NSA / FBI AA24-038A · AA25-239A · TTP graphs	Vendor PSIRTs Cisco · PAN · Fortinet · Ivanti	Commercial CTI Mandiant · Recorded Future · MS TI	MITRE ATT&CK G1017 · D3FEND · CAPEC
2 · PREEMPTIVE LAYER (RIGOR AI)	Attack Intelligence TTP graphs from threat feeds	Defense Intelligence Symbolic Model of Computation	Remediation Intel Risk-prioritized vendor fixes	Continuous Re-Verify Hourly · per config change
3 · CONTROL PLANE	NGFW · IPS · WAF PAN · Fortinet · Cisco · Check Point	Identity (IdP / IGA) Okta · Entra · CyberArk · Ping	EDR · XDR CrowdStrike · MS Defender · S1	Email · Web · DLP Proofpoint · Mimecast · Forcepoint
4 · BEHAVIORAL LAYER (ACECARD UEBA)	5 Signal Summarizers Auth · Process · Net · File · ID	1536-d Embedding OpenAI · Phi-4 (air-gapped)	Trajectory Analysis Drift · Velocity · CUSUM 4σ	Drift Direction 8 MITRE concepts · ABAC tags
5 · RESPONSE & AUDIT	SIEM · Data Lake Splunk · Sentinel · Chronicle	SOAR / Playbooks XSOAR · Splunk SOAR · Tines	Service Mgmt ServiceNow · JIRA tickets	Audit · Compliance NIST 800-53 · cATO · STIG

Each layer has visibility into the layers above and below. Rigor governs layers 2-3 (config-resident). ACECARD governs layer 4 (behavior-resident). MITRE ATT&CK is the shared vocabulary across all five.

Verdict: What the Combined Stack Delivers

Mapped against the full Volt + Salt Typhoon kill chain and the broader CISA framework.

WHAT IT COVERS	REMAINING GAPS (BY DESIGN)	RECOMMENDED FULL STACK
• Every known MITRE TTP for Volt Typhoon (G1017) and Salt Typhoon — preempted at config layer (Rigor) • Living-off-the-Land tradecraft — caught as behavioral drift even when binaries are legitimate (ACECARD) • Cross-domain identity fusion — one trajectory across AD/AAD/AWS/Okta/K8s (Composite Digital Signature) • Zero-day & unmapped TTPs — caught as deviation from baseline even with no MITRE label (ACECARD) • Insider threat & valid-account abuse — cohort z-score + cosine drift surfaces misuse (ACECARD) • Long-dwell stealth (Salt Typhoon's signature) — CUSUM 4σ on rolling 30-day baseline (ACECARD) • Mathematical proof of NIST 800-53 / SP800-207 / D3FEND control coverage (Rigor) • Continuous re-verification on every config change, every threat-feed update (Rigor)	• Endpoint runtime enforcement — ACECARD reads EDR telemetry; doesn't replace EDR. Pair with CrowdStrike / MS Defender / SentinelOne. • Email & phishing initial access — outside Rigor's NGFW pillar. Pair with Proofpoint / Defender for Office 365 / Abnormal. • OT/ICS-specific protocols — particularly for Volt Typhoon utility targets. Pair with Dragos / Claroty / Nozomi / TXOne. • Physical & supply-chain compromise — Rigor's third-party use case extends here partially. Pair with TPRM platforms. • Human factors — process layer, not technology. Pair with awareness training + tabletops. • Deception layer — adds high-fidelity tripwires post-preemption. Pair with Thinkst Canary / Acalvio.	Rigor AI Preemptive config verification — closes 80%+ of TTP paths before exploitation. Mathematical proof of posture. ACECARD UEBA Behavioral trajectories for valid-account abuse, LoTL, dwell-time, zero-days. ABAC enforcement. + EDR/XDR Endpoint runtime + in-memory enforcement. Telemetry into ACECARD. + Email Sec Phishing-resistant MFA + email gateway. Closes initial-access vector. + NDR + SIEM East-west visibility + log fabric. Substrate for detection + response. + OT/ICS (if applicable) Specialized protocol awareness for utilities, water, transport.

VERDICT: *Rigor AI + ACECARD UEBA = comprehensive defense against Volt Typhoon + Salt Typhoon. Add EDR + Email Security + NDR for full defense-in-depth.*

BUILD YOUR DOME

Preempt the next Typhoon. Detect what slips past.

Rigor AI is engaged with 20+ design partners across F500, federal, critical infrastructure, MSSPs, and nation states. ACECARD UEBA is operationally tested by 22nd Century Technologies — running the \$90M U.S. Army SOC/MDR contract with 800+ cleared analysts; USAF \$108M; FBI TSC \$56M; NAVAIR/USMC \$145M.

NEXT STEPS

1. **Pilot Rigor AI** — Formal Policy Analysis on your edge defense estate against Volt + Salt Typhoon TTPs
2. **Pilot ACECARD UEBA** — Replay Volt + Salt Typhoon scenarios on your telemetry; tune thresholds + cohorts
3. **Integrate** — Rigor's verified findings raise ACECARD's trust floor on entities traversing closed gaps
4. **Operationalize** — SaaS / on-prem / IL5 / IL6 / JWICS / cATO. Continuous re-verification + behavioral monitoring

Rigor AI: sales-ext@rigor.ai · Sundar Iyer, CEO · Navneet Yadav, CPO

22nd Century Technologies (TSCTI): Ravindra Shukla, Head of AI · ACECARD UEBA — UNCLASSIFIED // FOUO